PIA for Datality International

Editing :
Oladipupo Daniel
Evaluation :
Sweet Tech
Validation :
Oladipupo Team
Status :
In progress
100%

Validation

Risk mapping

Validation

Action plan

Fundamental principles

No action plan recorded.

Existing or planned measures

No action plan recorded.

Risks

No action plan recorded.

Validation

TO TRANSLATE - DPO and data subjects opinion

No data to display.

Context

Overview

What is the processing under consideration?

The '***RecruitSmart***' system is an AI-driven decision-support tool designed to streamline the initial stages of the recruitment process. The processing involves the automated extraction of professional skills, experience, and educational background from candidate CVs to generate a 'match-score' against specific job descriptions.
Distinct from a 'black-box' automated decision, the processing acts as a filtering layer to assist HR professionals. It includes two distinct phases:

Model Optimization: The training of the NLP (Natural Language Processing) model using a curated, pseudonymized historical dataset to ensure accuracy.

Operational Inference: The real-time analysis of new applicant data.
A critical component of this processing is the algorithmic fairness audit, ensuring the system does not reproduce historical biases related to gender, age, or origin

What are the responsibilities linked to the processing?

1. **Data Controller:** *Apex Datality Solutions Corp ADSC*

As the entity determining the "purposes and means," the Controller bears primary liability.

Key Responsibilities:

- Defining the legal basis for the AI (likely "Legitimate Interest" for screening).
- Conducting the final fairness audit to ensure the algorithm isn't discriminating.
- Managing Data Subject Rights (e.g., providing an explanation to a rejected candidate).
- Ensuring the "Human-in-the-Loop" remains active and trained.

2. **Joint Controller**: Apex Datality Group

And other Testers who used RecruitSmart across a group of companies where the global AI ethics policy was defined.

Key Responsibility: Determining the global parameters of the "success prediction" logic.

3. **Data Processor**: e.g., NeuralHire SaaS (The AI Software Provider)
This is the vendor providing the API or the cloud infrastructure.

Key Responsibilities (per GDPR Article 28):

1. Processing data strictly according to the Controller’s written instructions.

2. Ensuring the security of the processing (encryption of CVs at rest/in transit).
3. Notifying the Controller of any data breaches within 72 hours.
4. AI-Specific: Ensuring the model does not "leak" training data via Model Inversion.

4. **Sub-Processors**: AWS France

Key Responsibility: Providing the physical/virtual servers where the CV data is stored. Reviewed and confirmed vetted for Data Residency (keeping the data within the EU/EEA to please the CNIL's international transfer rules).

The AI Ethics & Compliance Officer: Responsible for the periodic bias-testing of the RecruitSmart model. They act as the bridge between the DPO (Data Protection Officer) and the technical team to ensure "Privacy by Design."

Are there standards applicable to the processing?

Section 1.3: Standards & Certifications Applicable

1. Technical & Organizational Standards
2. ISO/IEC 42001:2023 (AI Management System):
3. ISO/IEC 27001: This confirms that the CV data is stored in an environment with world-class information security management.
4. ISO/IEC 24089

2. **Approved Codes of Conduct (CNIL/EU Specific)**

- The Cloud Infrastructure Service Providers (CISPE) Code of Conduct:

- Europrivacy.

3. **AI-Specific Ethical Frameworks**

- CNIL’s Self-Assessment Guide for AI
- ALTAI (Assessment List for Trustworthy AI):
- NIST AI Risk Management Framework (AI RMF 1.0)

Evaluation : Acceptable
Evaluation comment :

1. Final Risk Evaluation Summary

In the software's Evaluation or Validation tab, you must provide a consolidated view of the project's safety. For an AI recruitment tool, use this professional framing:
Risk Level Statement: "After implementing the Redaction Engine and RBAC controls, the residual risk of illegitimate access is considered Acceptable (Medium)."

Justification: "The severity is mitigated by Pseudonymization—even in a breach, match-scores cannot be linked to individuals without the master key. The likelihood is lowered by MFA and IP Whitelisting."

2. Mandatory AI Compliance Statements
The CNIL specifically looks for these two "AI-recommendable" declarations in the final assessment:
Human-in-the-Loop Confirmation: "The AI system is strictly a decision-support tool; no candidate is automatically rejected. Final hiring decisions are always made by a human recruiter."

Non-Discrimination Guarantee: "Regular Bias Audits are scheduled (Quarterly) to ensure the NLP scoring does not create disparate impact based on protected characteristics."

3. The Action Plan (Corrective Measures)
If any section was marked as "Improvable," you must attach a specific task.

Action 1: "Conduct Adversarial Red-Teaming (Model Inversion tests) before full production launch to verify the model's resistance to data extraction attacks."

Action 2: "Provide 'Algorithmic Literacy' training to all HR staff by Q3 to ensure correct interpretation of AI match-scores."

4. Stakeholder Opinions
The CNIL methodology requires documenting the views of key figures before validation:

DPO Opinion: State that the Data Protection Officer has reviewed the Legal Basis (Legitimate Interest) and finds it proportionate.

Staff Representatives: If required by local labor law, note that the employee committee was consulted regarding the use of automated tools.
Final Step: Once you enter these, click "Ask for Validation" in the sidebar. This locks the version and prepares the official PDF report

Context

Data, processes and supporting assets

What are the data processed?

Section 2.1: Data Categories, Recipients, and Retention

DATA CATEGORY	SPECIFIC DATA POINTS	PURPOSE OF PROCESSING	STORAGE DURATION	RECIPIENTS
IDENTIFICATION	Full Name, Email, Phone Number, LinkedIn URL	Communication and profile verification.	2 years after last contact (per CNIL recruitment standards).	HR Department, Recruitment Manager.
PROFESSIONAL EXPERIENCE	Job titles, Company names, Tenure, Hard skills, Certifications	Main input for the AI "Match-Score" algorithm.	2 years after last contact.	HR Dept, AI Software Provider (NeuralHire SaaS).
EDUCATION	Degrees, Institutions, Graduation dates	Verification of academic prerequisites.	2 years after last contact.	HR Dept, Hiring Manager.
ALGORITHMIC METADATA	Candidate ID (pseudonymized), Match-score, Bias-check flags	Internal audit and model performance tracking.	5 years (for historical trend analysis/non-discrimination audits).	Data Science Team, DPO.

How does the life cycle of data and processes work?

1. Data Flow Diagram (Conceptual)
Since I am a text-based AI, I have structured this flow so you can easily visualize it or sketch it into your PIA document:

2. **Detailed Lifecycle Description**

Phase A: Collection & Input Minimization
Data enters the system via the company’s career portal.
The Process: Candidates upload their CVs and cover letters.
Key "Recommendable" Feature: Technical Pre-filtering. Before the AI processes the document, a "Sanitization Script" identifies and masks sensitive data points (e.g., photos, birth dates, or

addresses). This ensures the AI model is "blind" to protected characteristics, preventing Direct Discrimination.

Phase B: Processing & Algorithmic Inference
This is the "Black Box" stage, but we make it transparent.
The Process: The Natural Language Processing (NLP) engine breaks down the CV into "tokens" (keywords like "Python," "Project Management," "Bachelor's Degree"). These tokens are compared against the job's "Target Profile."

Key "Recommendable" Feature: Local Inference. The data is processed within a Sovereign Cloud (e.g., a localized instance in the EU). We avoid "Global Training Loops" where candidate data is sent back to a vendor to train their general model.

Phase C: Storage & Access Control
Once processed, the data is stored for HR review.
The Process: Data is stored in a relational database encrypted with AES-256.

Key "Recommendable" Feature: Role-Based Access Control (RBAC). The AI-generated "Match Score" is visible to recruiters, but the raw, unredacted CV is only accessible to the specific hiring manager for that role. This limits the "blast radius" of any internal data misuse.

Phase D: Use & Human Oversight
The AI provides a recommendation, not a final decision.
The Process: The system ranks candidates. The Recruiter reviews the top picks and decides who to interview.
Key "Recommendable" Feature: The Override Log. Every time a human ignores the AI's recommendation (e.g., interviewing a "low-score" candidate), the system logs the reason. This creates a "Fairness Audit Trail" which the CNIL highly recommends for Algorithmic Accountability.

Phase E: Retention & Secure Destruction
The data lifecycle ends when the purpose is fulfilled.
The Process: Per CNIL guidelines, candidate data is kept for 2 years from the last contact to allow for legal defense against discrimination claims.
Key "Recommendable" Feature: Automated Cryptographic Erasure. At the 2-year mark, the system doesn't just "delete" the entry; it destroys the unique encryption key for that candidate's record. This makes the data unrecoverable, satisfying the Right to be Forgotten (Art. 17 GDPR).

What are the data supporting assets?

Asset Category	Specific Supporting Assets	Role in RecruitSmart
Hardware / Infrastructure	AWS EC2 Instances (Paris Region)	Virtual servers providing the compute power for the NLP engine.
Operating Systems	Ubuntu 22.04 LTS (Hardened)	The secure OS environment where the AI scripts run.

Database Management (DBMS)	PostgreSQL 15 (Managed)	Stores the CANDIDATES and NLP_SKILLS tables shown in your diagram.
AI/ML Frameworks	Python 3.11 / spaCy / PyTorch	The business applications/libraries used to build the "Scoring Model."
Business Applications	RecruitSmart Web Portal (React/Node.js)	The interface where candidates upload CVs and HR views scores.
Security & Config	HashiCorp Vault / Terraform	Manages the Encryption Keys and infrastructure-as-code configurations.
Office/Admin Tools	Microsoft 365 (via SSO)	Used by HR to receive automated notifications about top candidates.
Network Assets	VPC (Virtual Private Cloud) & WAF	Isolates the AI processing from the public internet to prevent leaks.

Fundamental principles

Proportionality and necessity

Are the processing purposes specified, explicit and legitimate?

1. **The Purposes are Specified** (The "What")

We do not use a vague term like "improving HR." We break it down into precise sub-purposes:

Primary Purpose: Automated sorting of job applications to identify candidates whose professional skills best match the specific requirements of a job description.

Secondary Purpose (Audit): Periodic statistical analysis of "Match Scores" to detect and correct potential algorithmic bias (e.g., ensuring the AI isn't favoring specific genders or universities).

Tertiary Purpose (Evidence): Retention of candidate data for the duration of the legal prescription period (2 years) to defend against potential discrimination claims.

2. **The Purposes are Explicit (The "How they know")**
The purpose isn't hidden in the "fine print."
Transparency: Candidates are informed via a Privacy Notice on the upload portal before they submit their CV.

Clarity: The notice explicitly states: "Your CV will be analyzed by an AI tool to assist our recruiters in identifying relevant skills. A human recruiter makes all final interview decisions."

AI-Specific: We explicitly inform them that their data is used to "score" their profile against a job description, satisfying GDPR Article 13(2)(f).

3. **The Purposes are Legitimate (The "Legal Right")**
The processing is balanced against the rights of the candidates.
Legal Basis: We rely on Legitimate Interest (Art. 6.1.f GDPR) for the company to manage recruitment efficiently, AND Legal Obligation for the retention of data to prove non-discriminatory hiring practices.
The "Legitimacy Test": The processing is legitimate because it focuses strictly on professional data (skills/experience) and excludes sensitive data (religion, health, etc.). By using the Redaction Engine shown in our diagram, we ensure the "legitimate interest" of the company does not override the candidate's right to privacy.

What are the legal basis making the processing lawful?

Section 1.5: Legal Basis for Processing

1. **Pre-Contractual Steps** (Primary Operational Basis)
Legal Basis: Necessary for the performance of a contract or to take steps at the request of the data subject prior to entering into a contract (Art. 6.1.b GDPR).

Application: When a candidate applies via our portal, processing their CV is a necessary step to evaluate their application for a potential employment contract.

2. **Legitimate Interest** (AI Optimization & Bias Mitigation)
Legal Basis: Necessary for the purposes of the legitimate interests pursued by the controller (Art. 6.1.f GDPR).

Application:
Recruitment Efficiency: The company has a legitimate interest in using AI to manage high volumes of applications effectively.
Fairness Audits: You have a legitimate interest in analyzing "Match Scores" to ensure the model is not biased. The CNIL specifically recommends legitimate interest over consent for diversity and fairness monitoring because it avoids the power imbalance inherent in hiring.

3. **Legal Obligation (Data Retention)**
Legal Basis: Necessary for compliance with a legal obligation (Art. 6.1.c GDPR). Application: In France, recruiters must retain records to prove compliance with non-discrimination laws (Labour Code). The CNIL recommends a 2-year retention period specifically to meet these legal defense requirements.

4. **Explicit Consent** (Future Talent Pool - Optional)
Legal Basis: The data subject has given consent for one or more specific purposes (Art. 6.1.a GDPR).

Application: If you wish to keep a candidate's CV for future job openings beyond the specific role they applied for, you must obtain their explicit, opt-in consent.

Are the data collected adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation')?

"Data minimisation is achieved through an automated pre-processing layer that filters out non-professional attributes. By isolating 'Professional Tokens' (Skills/Experience) from 'Identity Attributes' (Name/Gender), the RecruitSmart AI ensures that the processing is strictly limited to data that is objectively relevant to the job description, thereby reducing the risk of discriminatory output.

Section 2.4: Data Minimisation & Relevance

We adhere to Data Minimisation (Article 5.1.c GDPR) by categorizing data into "Necessary for Inference" and "Necessary for Communication.		
Data Category	Relevance to Purpose	Why it is "Limited to Necessity"
Professional Experience	Core logic: Required to match candidate history with job requirements.	We only extract job titles and durations. We do not store full descriptive paragraphs if they don't contain specific skill keywords.
Technical Skills	Core logic: Essential for the "Match-Score" calculation.	Limited to validated keywords (e.g., "Python," "Project Management") found in the CV.
Education	Core logic: To verify if the candidate meets minimum academic criteria.	We process only the highest degree obtained and the field of study.
Contact Info	Communication: To invite successful candidates for interviews.	Limited to Email/Phone. We do not collect home addresses unless a contract is being drafted.
Pseudonymized ID	Audit/Security: To track the AI's performance without using names.	Replaces the candidate's real name during the algorithmic scoring phase to prevent human or machine bias.

Are the data accurate and kept up to date?

Data accuracy is guaranteed through a 'Candidate-in-the-loop' validation step where applicants review and confirm the AI's data extraction. Furthermore, the NLP model undergoes bi-monthly 'Accuracy Benchmarking' against human-annotated datasets to ensure that the parsing logic remains aligned with modern recruitment terminology and formatting.

Section 2.5: Accuracy and Data Quality

For an AI recruitment tool, accuracy is maintained through a Multi-Layer Verification Process:		
Strategy	Technical Action	Why it is "Recommendable"
Source Integrity	Candidate-Led Input: Data is sourced directly from the candidate's uploaded CV.	Minimizes "third-party noise" or outdated scraping errors.
OCR/NLP Validation	Confidence Scoring: The NLP engine assigns a "Confidence Score" to extracted text (e.g., "98% sure this is a Degree").	If the score is low, the system flags the CV for Manual Entry instead of guessing.
User Confirmation	The "Review & Edit" Screen: After uploading, the system shows the candidate the extracted data points.	Allows the Data Subject to correct any parsing errors before the AI scores them.
Model Freshness	Dynamic Skill Mapping: The "Target Profiles" are updated by HR for every new job post.	Ensures the AI isn't scoring candidates against outdated or "stale" job requirements.

What are the storage duration of the data?

The storage durations are strictly aligned with the CNIL's recruitment guidelines (2 years from the last contact). This period is legally justified by the necessity to maintain evidence in the event of a litigation regarding hiring bias. From a technical standpoint, the 2-year window allows for meaningful 'Back-testing' of the AI model's accuracy against actual employee performance

Section 2.6: Storage Durations and Justifications

Data Type	Retention Period	Legal & Technical Justification
Active Application Data (CV, Cover Letter, Identity)	Duration of the recruitment process + 2 years.	Legal Requirement: Follows CNIL simplified standard NS-046. Justified by the need to defend against discrimination claims (Statute of limitations).
Algorithmic "Match Scores" & Decision Logs	2 years (linked to the candidate profile).	Processing Purpose: Necessary to provide an explanation to the candidate if they exercise their Right to an Explanation (Art. 22).

Anonymized Training Datasets (No PII)	5 years (or until the model version is retired).	Technical Necessity: High-quality historical data is required to perform long-term bias audits and ensure the AI's "success prediction" remains accurate over time.
Technical Logs (IP, Connection timestamps)	1 year.	Security Requirement: Standard duration for cybersecurity forensics and detecting fraudulent bot-applications.

Fundamental principles

Controls to protect the personal rights of data subjects

How are the data subjects informed on the processing?

Transparency is ensured through a multi-layered notification system. Candidates are informed of the AI's role prior to data submission. The logic is explained in non-technical terms, focusing on the professional criteria weighted by the model, thereby fulfilling the transparency requirements of Art. 22 without compromising the company's proprietary trade secrets

Section 2.7: Information Provided to Data Subjects

We use a Layered Information Approach to ensure transparency without overwhelming the candidate or revealing trade secrets.		
Information Layer	Method of Delivery	Key Content Included
Layer 1: The "Notice"	Pop-up/Header on the CV Upload page.	Identity of the Controller, the use of AI for skill-scoring, and the "Human-in-the-loop" guarantee.
Layer 2: The "Privacy Policy"	Hyperlink at the footer of the portal.	Full details on Retention (2 years), Legal Basis (Legitimate Interest), and the List of Rights (Access, Erasure, Object).
Layer 3: The "Logic Summary"	FAQ/Help Icon next to the upload button.	Explanation of the weighting criteria (e.g., "We prioritize years of experience and specific technical certifications").

What Specific Information is Given?
According to GDPR Articles 13 & 14 and CNIL AI Guidelines, we must provide:

The Existence of Automated Decision-Making: We explicitly state: "An algorithmic tool assists our recruiters by ranking applications based on professional qualifications."

Meaningful Information about the Logic: We describe the "Input Features" (Skills, Education, Tenure) without revealing the exact mathematical code (Trade Secret Protection).

The Envisaged Consequences: We inform the candidate that a low "Match-Score" may result in their application being reviewed later than higher-scoring profiles, but that no candidate is rejected without human verification.

Right to Human Intervention: We clearly state their right to obtain human intervention and to contest the AI's "Match-Score."

If applicable, how is the consent of data subjects obtained?

Consent is strictly limited to non-essential secondary purposes (e.g., Talent Pool inclusion). Controls include a dedicated 'Consent Log' and a self-service portal for instantaneous withdrawal. We ensure that the refusal to provide consent for secondary processing has no technical impact on the AI's objective assessment of the candidate's professional qualifications.

How can data subjects exercise their rights of access and to data portability?

Consent is strictly limited to non-essential secondary purposes (e.g., Talent Pool inclusion). Controls include a dedicated 'Consent Log' and a self-service portal for instantaneous withdrawal. We ensure that the refusal to provide consent for secondary processing has no technical impact on the AI's objective assessment of the candidate's professional qualifications."

Section 2.8: Consent Management & Control

For RecruitSmart, consent is only obtained for Secondary Purposes, such as keeping a CV in the "Talent Pool" after a specific job opening is closed.						
Feature	Legal Basis	Consent Method				
Initial CV Scoring	Legitimate Interest	No consent (Notice provided).				
Talent Pool (2-year storage)	Consent (Art. 6.1.a)	Active Opt-in (Unchecked box).				
Future Job Alerts	Consent (Art. 6.1.a)	Granular Checkbox.				

Controls to Ensure Consent is "AI-Recommendable"
The "Unchecked Box" Rule: Per GDPR Art. 7, consent must be an "unambiguous affirmative act." The RecruitSmart portal uses empty checkboxes. Pre-ticked boxes are strictly forbidden.

Granularity: Candidates are not forced to "Accept All." They can consent to the Talent Pool but refuse "Future Marketing Emails."
The "Withdrawal" Dashboard: Every candidate has an "Applicant Portal" where they can see their active consents and toggle them to "OFF" at any time. This fulfills the "as easy to withdraw as to give" requirement.
Consent Timestamping (The Audit Trail):

The Control: For every "Opt-in," the system logs: Candidate_ID, Timestamp, IP_Address, and Version of Privacy Policy.

Why it's Recommendable: This provides the Proof of Consent required during a CNIL audit without revealing the candidate's actual name to the audit team (pseudonymization).

The "No-Penalty" Guarantee
To ensure consent is truly "free," the system is programmed so that unchecking the Talent Pool box does not affect the AI "Match-Score" for the current application. The AI logic is completely decoupled from the consent status.

How can data subjects exercise their rights to rectification and erasure?

The rights to rectification and erasure are operationalized via a self-service Applicant Portal. Rectification is integrated into the pre-processing phase to ensure algorithmic accuracy. Erasure is guaranteed through an automated 'Purge & Shred' protocol that includes cryptographic key destruction and the immediate propagation of deletion requests to all downstream sub-processors

Section 2.10: Procedures for Rectification and Erasure

1. **The Right to Rectification** (Art. 16 GDPR)
If the NLP (Natural Language Processing) misinterprets a "Master's Degree" as a "Bachelor's," it unfairly lowers the score.

The Technical Mean: The "Candidate Validation" Screen. Immediately after upload, the system displays the extracted "Professional Tokens" (Skills, Education, Tenure) to the candidate.

The Action: Candidates can click "Edit" to manually correct any parsing errors before the final "Match-Score" is generated.
AI-Pro Step: Once a correction is saved, the system triggers an "Automatic Re-Scoring" to ensure the AI's output is based on the verified "ground truth" provided by the human.

2. **The Right to Erasure / "To be Forgotten"** (Art. 17 GDPR)
The Technical Mean: A "Right to Erasure" request button in the Applicant Portal or a direct email to the DPO.
The Action: Clicking this triggers an automated "Cascade Deletion."
AI-Pro Step (Cryptographic Erasure): As shown in your [Data Flow Diagram], the system uses Cryptographic Shredding. When a deletion is requested, the system destroys the unique encryption key associated with that candidate’s CANDIDATE_ID. Even if the encrypted data exists in a backup, it is rendered mathematically unrecoverable.

Controls & Response Times
The 30-Day Rule: All requests are acknowledged immediately and fully processed within one month per GDPR Article 12(3).

Propagation to Sub-Processors: RecruitSmart sends an automated API "Delete" command to any third-party processors (e.g., the cloud host or a coding test provider) to ensure the data is scrubbed across the entire technical stack.

The "No-Penalty" Guarantee: Exercising the right to rectification never negatively impacts a candidate's score; it only improves the accuracy of the matching logic.

How can data subjects exercise their rights to restriction and to object?

Objection and restriction rights are managed through an 'Opt-out of Automation' workflow. Upon objection, the system enforces a technical bypass of the algorithmic scoring layer, ensuring the data subject is evaluated exclusively through human intervention. Restriction requests trigger a 'Logical Lock' on the database entry, preventing further processing while maintaining data integrity for dispute resolution

Section 2.11: Rights to Restriction and Objection

1. The Right to Object (Art. 21 GDPR)

Since our legal basis is Legitimate Interest, candidates have a legal right to object to the AI-driven scoring of their profile.

The Control: A "Manual Review Request" checkbox on the application form.

The AI-Pro Workflow: If a candidate objects, the system bypasses the NLP/Scoring Model entirely. The CV is flagged with a "Human-Only" tag and routed directly to an HR manager’s manual queue.

The Guarantee: The project ensures that choosing "Manual Review" does not lower the candidate's priority or visibility; it simply changes the method of evaluation.

2. The Right to Restriction (Art. 18 GDPR)

This is used if a candidate disputes the accuracy of the AI's "Match-Score" or the legality of the data used.

The Control: A "Freeze Processing" status in the Supporting Assets (Database).

The AI-Pro Workflow: When restriction is invoked, the candidate's profile is moved to a "Locked" state. It remains stored (to preserve the evidence) but is hidden from the Scoring Model and the HR Dashboard.

Duration: The data stays "frozen" until the dispute (e.g., a bias claim or data accuracy issue) is resolved by the DPO.

Specific Controls for "AI-Recommendable" Implementation:

Direct Contact Point: A dedicated "Privacy Request" button in the Applicant Portal that pre-fills an email to the DPO with the subject line: "Exercise of Right to Object - [Candidate ID]".

Automated Workflow Triggers: When an objection is logged, the system triggers a "Processing Block" at the API level, ensuring the AI model cannot pull that specific Candidate_ID into its next batch-scoring run.

Transparency of Choice: The Information Notice (Section 2.7) explicitly states: "You have the right to object to the automated analysis of your CV. In such cases, your application will be reviewed manually by a member of our recruitment team."

Are the obligations of the processors clearly identified and governed by a contract?

All processing activities are governed by Article 28-compliant contracts. We have specifically mandated that our AI provider (NeuralHire) maintains Sovereign Data Hosting within the EEA. Furthermore, our contracts explicitly prohibit the 're-use' of candidate data for third-party machine learning training, ensuring the integrity of our trade secrets and candidate privacy

Processor Name	Mission/Scope	Duration	Purpose of Processing	Safeguards & Certifications
NeuralHire SaaS (AI Logic Provider)	Provision of NLP API and Scoring Engine.	Duration of the service contract.	Skill extraction and match-score generation.	ISO 42001 (AI Management); Europrivacy certified.
AWS France (Cloud Hosting)	Infrastructure (IaaS) and Database hosting.	Until contract termination.	Secure storage of CVs and model metadata.	ISO 27001; CISPE Code of Conduct (GDPR compliant cloud).
SendGrid (Email Notification)	Automated candidate communication.	Temporary (Transactional).	Sending interview invites or rejection notices.	SCCs (Standard Contractual Clauses) for data transfers.

Contractual Clauses:
To ensure this doesn't look like a generic draft, specify these four mandatory instructions included in your contracts:
Strict Purpose Limitation: The processor is strictly forbidden from using "RecruitSmart" candidate data to improve their general AI models or for any purpose other than our specific recruitment scoring.

Right to Audit: The contract grants the Data Controller (your company) the right to conduct an annual security and "bias audit" of the processor's environment.

Sub-processor Authorization: The processor cannot hire a new sub-processor (e.g., a different cloud provider) without your prior written authorization.

Assistance with Data Subject Rights: The processor must have a technical API that allows you to trigger Erasure or Rectification commands that propagate to their systems instantly.

Documented Processing Instructions:
All processing is governed by a Standard Data Processing Addendum (DPA).

The Mission: "The Processor shall only process personal data on documented instructions from the Controller, including with regard to transfers of personal data to a third country."

Confidentiality: "The Processor ensures that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality."

In the case of data transfer outside the European Union, are the data adequately protected?

The RecruitSmart architecture prioritizes Local Data Residency within the EEA. For necessary auxiliary services located in the U.S., we rely on the EU-U.S. Data Privacy Framework supplemented by the 2021 Standard Contractual Clauses. Furthermore, we have implemented 'Data Minimization at Edge,' ensuring that only non-sensitive identifiers are transferred, while the core AI-processed professional data remains on sovereign French infrastructure.

Section 1.7: Data Transfers Outside the EU/EEA

Processor / Tool	Destination Country	Adequacy Status	Transfer Mechanism & Safeguards
AWS France (Primary Cloud)	France (EU)	N/A	Local Residency: All CV data and AI models are stored in the eu-west-3 region (Paris). No transfer occurs.
SendGrid (Email API)	USA	Partial (DPF)	EU-U.S. Data Privacy Framework: SendGrid is certified under the DPF. We also enforce Standard Contractual Clauses (SCCs) as a backup.
NeuralHire Support (AI Logic)	USA / UK	Adequate (UK)	UK: Beneficiary of an adequacy decision. USA: Access is limited to "Technical Support" only via Virtual Desktop Infrastructure (VDI) where data never leaves the EU server.

1. **The "Sovereign Cloud" Principle**
State that RecruitSmart follows a "Cloud-Centre" approach.
The Control: Technical configurations in Terraform (your Supporting Asset) prevent the creation of database instances outside of the European Economic Area (EEA).

2. **Supplemental Measures (TIA - Transfer Impact Assessment)**
For any U.S.-based tool (like SendGrid), the CNIL requires more than just a contract.
Technical Measure: Pseudonymization at Source. Before an email is sent via a U.S. processor, the system only sends the *Email_Address* and a *Template_ID*. The candidate's CV, match-score, and professional history remain strictly in France.

Encryption: All data in transit to the U.S. is encrypted using TLS 1.3 with keys managed exclusively by the Data Controller in the EU (BYOK - Bring Your Own Key).

3. **The "No-Access" Support Policy**
The Control: If a U.S. engineer needs to fix a bug in the AI scoring model, they are granted "Zero-Trust" remote access. They can see the code, but they cannot download or export the candidate database.

Risks

Planned or existing measures

Traceability & Robustness

3.3: **AI-Specific Controls**

- The "Explainability" Log: For every score generated, the system saves a "Feature Importance" report (e.g., "Score 80% due to: [Python: High], [Tenure: Med]"). This allows the DPO to audit the logic of any specific decision.

- Adversarial Testing: We perform "Penetration Testing" specifically for AI—attempting to "trick" the model into revealing private training data through Model Inversion attacks.

- Automated Deletion Triggers: As shown in your diagram, the "Purge Trigger" is a hard-coded script that cannot be manually overridden, ensuring the 2-year retention limit is absolute.

Governance And Technical Control

3.1: **Organizational Measures (Governance)**

- AI Ethics Committee: A cross-functional group (HR, Legal, DPO, Data Science) that meets quarterly to review the AI's "Match-Score" distribution and check for unintended bias.

- Staff Training: Mandatory training for all recruiters on "Algorithmic Literacy"—ensuring they understand that the AI is a recommendation tool, not a final decision-maker.

- Incident Response Plan: A specific protocol for "Model Anomalies" (e.g., if the AI suddenly gives everyone a 0 score), which includes immediate processing suspension.

3.2: **Logical Security (Technical Controls)**

- Identity & Access Management (IAM):
- Role-Based Access (RBAC): Recruiters see scores; only the Data Science lead can access the "Scoring Model" logic; only the DPO can access the "Secure Archive" logs.
- Multi-Factor Authentication (MFA): Mandatory for all access to the Supporting Assets (AWS/PostgreSQL).
- Data Minimization at the Edge: The Redaction Engine (as seen in your diagram) automatically strips sensitive attributes before the AI processes the file, preventing the model from ever "knowing" the candidate's gender or age.
- Encryption Strategy: At Rest: All CVs in the Secure Archive are encrypted using AES-256. In Transit: All data flows move via TLS 1.3.

Risks

Illegitimate access to data

What could be the main impacts on the data subjects if the risk were to occur?

Identity Theft & Phishing, Professional & Reputational Damage, Loss of Privacy & Stalking, Discrimination Risk

What are the main threats that could lead to the risk?

Injection Attacks, Credential Harvesting, Exploiting flaws in the RBAC, Privilege Escalation, Inversion / Inference Attack, Repeatedly querying the AI API, Data Exfiltration

What are the risk sources?

Malicious External Actor (Hacker), Professional cybercriminals, Negligent Internal Staff, Malicious Insider: A disgruntled employee, Bribed recruiter, Competitor / Corporate Spy

Which of the identified planned controls contribute to addressing the risk?

Traceability & Robustness, Governance And Technical Control

How do you estimate the risk severity, especially according to potential impacts and planned controls?

Important, The Severity is estimated as High (3) because the processing involves extensive professional and contact data of thousands of individuals. While our Redaction Engine and Pseudonymization measures mitigate the risk of mass discrimination during a breach, the potential for identity theft and professional reputational damage remains significant for the data subjects if their contact information and match-scores are compromised.

How do you estimate the likelihood of the risk, especially in respect of threats, sources of risk and planned controls?

Limited, The likelihood of illegitimate access is estimated as Limited because, although the risk sources (hackers) have the capability to launch automated attacks, our existing and planned controls create a high barrier to entry. Specifically, the use of Multi-Factor Authentication (MFA) and IP Whitelisting makes credential harvesting and external database access 'difficult' for unauthorized sources. Furthermore, the Redaction Engine reduces the value of any potentially accessed data, lowering the incentive for targeted attacks.

Risks

Unwanted modification of data

What could be the main impacts on the data subjects if the risk were to occur?

Identity Theft & Phishing

What are the main threats that could lead to the risk?

Credential Harvesting, Injection Attacks

What are the risk sources?

Malicious External Actor (Hacker), Bribed recruiter

Which of the identified controls contribute to addressing the risk?

Governance And Technical Control, Traceability & Robustness

How do you estimate the risk severity, especially according to potential impacts and planned controls?

Limited

How do you estimate the likelihood of the risk, especially in respect of threats, sources of risk and planned controls?

Limited

Risks

Data disappearance

What could be the main impacts on the data subjects if the risk were to occur?

Professional & Reputational Damage

What are the main threats that could lead to the risk?

Privilege Escalation

What are the risk sources?

Malicious Insider: A disgruntled employee

Which of the identified controls contribute to addressing the risk?

Traceability & Robustness

How do you estimate the risk severity, especially according to potential impacts and planned controls?

Important, Sensitive data has been breached

How do you estimate the likelihood of the risk, especially in respect of threats, sources of risk and planned controls?

Maximum, Affected data subjects must be contacted immediately to safeguard sensitive data that has been breached

Risks

Risks overview